M9

AI Impact & Risk Assessment

Module 9 — Asking “what could go wrong, and for whom?”

307307 — BI Methods for Generative AI

AI Governance · University of Petra

Lecturer: _____ Date: _____



AI Governance in Practice — Hemang Doshi (Packt, 2026)

A Question to Start With



Figure 9.1 from AI Governance in Practice (Hemang Doshi, Packt, 2026).

The question

A university plans an AI tool that ranks scholarship applications. Before it goes live, what should it check?

Today's idea

"It works and it saves time" is not enough. Ask who is affected, how it could go wrong, and who is responsible.

What You Will Be Able to Do

1. **Explain** what an AI impact assessment (AIIA) is and why standards and laws ask for one.
2. **Walk through** the seven steps of an AIIA and the main areas of impact.
3. **Identify, score and rank** AI risks using likelihood × impact.
4. **Choose a treatment** for each risk and record it in a risk register.

Impact First, Then Risk

AI Impact Assessment (AIIA)

Who could be affected, and how?

- Looks at people, rights, society and the organization
- Done before launch, and again after

AI Risk Assessment

How likely, how serious, and what will we do?

- Turns impacts into scored risks
- Chooses a treatment for each one

Asked for by: ISO/IEC 42001 · EU AI Act (high-risk systems) · NIST AI RMF · GDPR (data protection impact assessments)

Different words, same idea: find harm early, write it down, keep checking.

Eight Areas of Impact

1 Individuals & rights

Unfair rejection of a group of applicants; no way to appeal

2 Ethics & society

Trust in how aid is decided; over-reliance on automation

3 Legal & regulatory

Student-data protection and equal-treatment rules

4 Technical & operations

Less accurate for unusual transcripts, such as transfer students

5 Safety & security

Forged documents; stolen applicant data

6 Organization & business

Complaints, reputation, and changing committee roles

7 Environment

Energy used to train and run large models

8 Third parties

Vendor model and cloud hosting: who is responsible?

Areas follow Chapter 9 of the book. Examples are ours: a fictional Campus Scholarship Screener.

Seven Steps of an AIIA

1 Understand the system

What it does, who uses it, what data it needs, who is affected

2 Identify impacts

Fairness, privacy, legal, safety, security, reputation

3 Rate severity & likelihood

Which problems are serious, and which are probable?

4 Decide controls

Human review, bias testing, security, monitoring

5 Document

Record impacts, controls, owners and decisions

6 Get approval

Risk, legal, security and the governance committee sign off

7 Monitor & review

Reassess after changes to the system, data, purpose or rules

How to remember

Steps 1–3: understand

Steps 4–5: respond

Steps 6–7: govern

An Assessment Is Not a One-Time Event



Figure 9.2 from AI Governance in Practice (Hemang Doshi, Packt, 2026).

Reassess when…

- The model or its training data changes
- The system is used for a new purpose
- Laws, standards or policies change
- Monitoring or incidents reveal new problems

An assessment is a living record, not a certificate.

Six Types of AI Risk

Technical

Wrong or worsening outputs

Example: The model ranks unusual transcripts poorly

Ethical

Unfair or biased outcomes

Example: Past decisions favored one group; the model repeats them

Legal & regulatory

Breaking laws or contracts

Example: Mishandling applicants' personal data

Security

Attacks on data or the model

Example: Forged documents that fool the screener

Operational

Poor use or oversight

Example: The committee trusts the ranking without checking

Reputational

Loss of public trust

Example: A news story: "the algorithm that rejected me"

Risk types follow Chapter 10 of the book. Examples are from our fictional Campus Scholarship Screener.

Four Steps of Risk Assessment

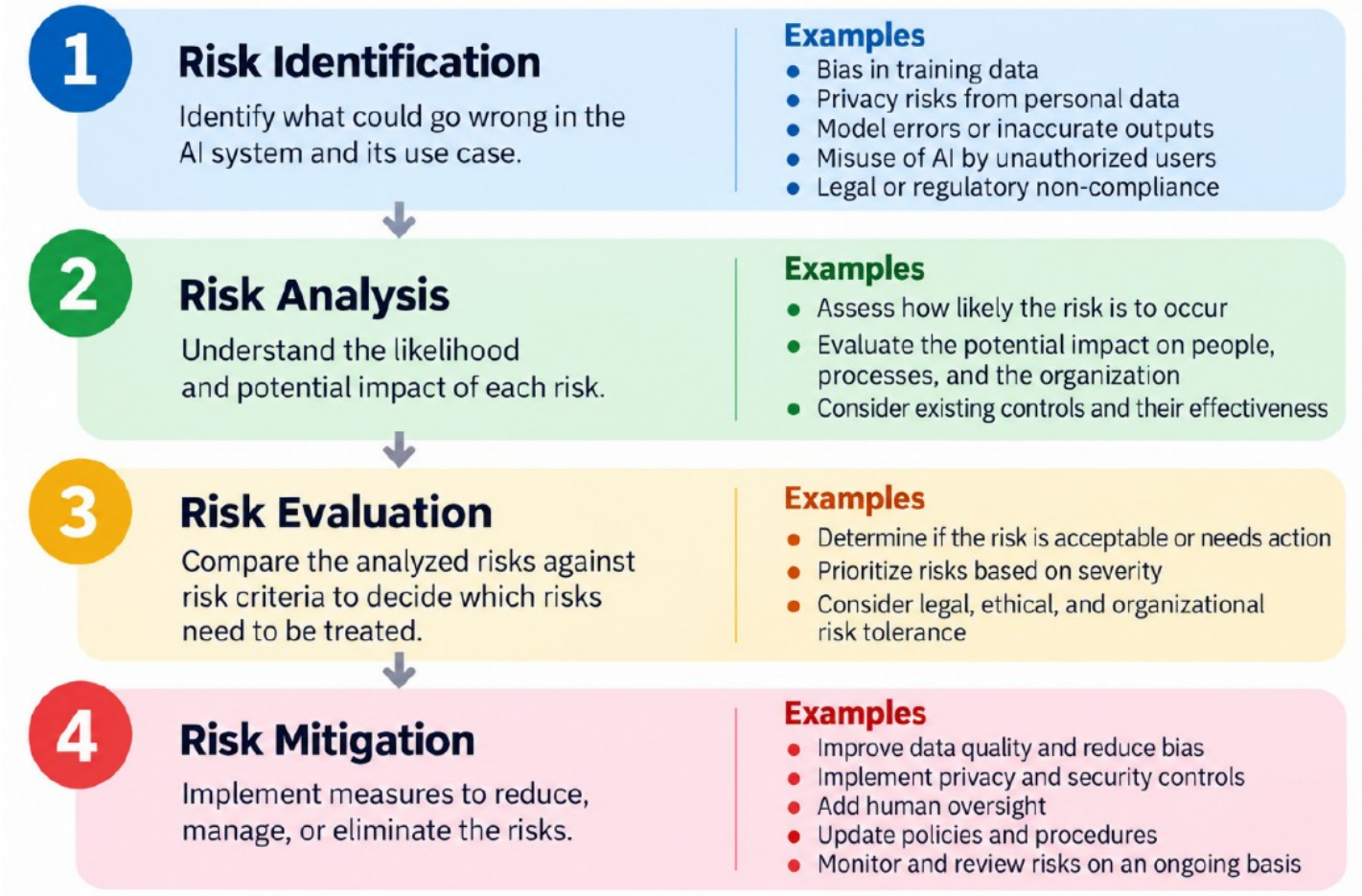


Figure 10.1 from AI Governance in Practice (Hemang Doshi, Packt, 2026).

Where each step appears today

1. **Identify** — seven ways to find risks
2. **Analyse** — score = likelihood × impact
3. **Evaluate** — is the score acceptable?
4. **Mitigate** — avoid, reduce, transfer, accept

A risk register records all four.

Finding Risks: Seven Techniques

1. **Workshops** — A mixed team brainstorms what could go wrong
2. **Risk checklists** — Standard lists of risk types so nothing is missed
3. **Past incidents** — Learn from AI failures that already happened
4. **Stakeholder analysis** — Who is affected, and how?
5. **Technical review** — Test accuracy, security and data quality
6. **Documentation review** — Missing limits or data sources are a risk too
7. **Lifecycle review** — Check every stage, from data to retirement

Free resources to try

AI Incident Database
incidentdatabase.ai

MIT AI Risk Repository
airisk.mit.edu/risks

Both links are cited in Chapter 10.

Scoring a Risk: Likelihood × Impact

Impact ↓ / Likelihood →	Low (1)	Medium (2)	High (3)
High (3)	3	6	9
Medium (2)	2	4	6
Low (1)	1	2	3

Scoring scheme as in Tables 10.1 and 10.2 of the book, rebuilt here. Each organization sets its own scales.

Worked examples

Biased ranking: impact 3 × likelihood 3 = 9, so High

Vendor delays results: impact 1 × likelihood 2 = 2, so Low

Low · 0–3

Standard controls and routine monitoring

Medium · 4–6

Needs attention, defined controls and periodic review

High · above 6

Immediate action, strong controls, senior management oversight

Four Ways to Treat a Risk

1 Avoid

Do not proceed, or drop the risky part.

Example: No automatic rejection emails: people decide declines.

2 Reduce

Add controls that lower the likelihood or the impact.

Example: Bias testing, human review of every decline, monitoring.

3 Transfer

Share the risk by contract or insurance.

Example: Vendor warranties and service levels. You stay accountable.

4 Accept

Keep a small risk and keep watching it.

Example: Formally approved, documented, reviewed later.

Goal: what is left over (residual risk) must fit the organization's risk appetite.

The Risk Register

ID	Risk	Type	L × I	Level	Treatment and control	Owner
R1	Model ranks transfer students below similar applicants	Ethical	3 × 3 = 9	**High**	Reduce: test results by applicant group; committee reviews every decline	Committee chair
R2	Uploaded applicant documents exposed through the vendor cloud	Security	2 × 3 = 6	**Medium**	Reduce and transfer: encryption, access limits, vendor contract clause	IT security officer
R3	Committee approves the shortlist without checking the reasons	Operational	3 × 2 = 6	**Medium**	Reduce: show reasons for each ranking; require a sample review	Committee chair

Sample rows from the fictional Campus Scholarship Screener. L × I = likelihood × impact.

Good to know: AI risks should live in the organization's main (enterprise) risk register where possible, and the register is reviewed whenever the system, its data or its use changes.

Key Takeaways

1. An AI impact assessment asks who is affected and how, before and after launch.
2. Look across eight areas of impact; not every area matters equally for every system.
3. Risk assessment has four steps: identify, analyse, evaluate, treat.
4. Score = likelihood × impact. The level decides how fast and how strongly we act.
5. Avoid, reduce, transfer or accept, record it in a risk register, and reassess when things change.

Discussion and Activity

Discuss

1. Who is affected by the scholarship screener without ever seeing it?
2. Would you let the tool send automatic “not shortlisted” emails? What changes if a person checks first?
3. Which is worse here: a data leak or an unfair ranking? How would you score each?

Activity

Assess the Campus Scholarship Screener (a fictional scenario)

A. Understand the system

B. Fill in the impact table

C. Build a risk register of five risks

D. Recommend: approve, approve with conditions, or do not approve

Groups of 3–4. Handout: Module9_Impact_Risk_activity.docx